

Ex : 5 Implementing Controls & Compensating Control Attestation**Date: 28.07.2026****Aim:**

To implement security controls in Eramba and document a compensating control attestation when the primary control cannot be implemented.

Procedure:

Step 1: Log in to Eramba

1. Open your Eramba dashboard.
2. Log in using your Email and Password.
3. From the left-side menu, select Control Catalog.

Step 2: Create a Control

1. Go to Control Catalog.
2. Click Add / Create Control.
3. Enter the control details.

Example:

Field	Example
Control Name	Multi-Factor Authentication
Description	Require MFA for user access to critical systems
Control Type	Preventive
Owner	IT Security Team
Status	Implemented
Frequency	Continuous

4. Save the control.

Step 3: Define the Control Implementation

1. Open the control you created.
2. Add information about how the control is implemented.
3. Specify the responsible person/team.

4. Add supporting evidence if available.
5. Save the changes.

Example evidence: MFA configuration screenshot, security policy, audit report, or access-control document.

Step 4: Associate the Control with a Risk

1. Go to Risk Management.
2. Select Asset Risks, Business Risks, or the relevant risk section.
3. Open an existing risk.
4. Find the Controls / Treatment / Countermeasures section.
5. Associate the newly created control with the risk.
6. Save.

Example:

Risk: Unauthorized access to company systems

Control: Multi-Factor Authentication

Treatment: Implement MFA for critical systems

Step 5: Verify Control Status

Check the control's implementation status.

For example:

- Implemented → Control is operating.
- Partially Implemented → Control is only partly implemented.
- Not Implemented → Control has not been implemented.

For the experiment, select Implemented for the primary control if you are demonstrating a normal control implementation.

Compensating Control Attestation

A compensating control is an alternative control used when the original/required control cannot be implemented directly but the organization still needs to reduce the risk.

Step 6: Identify a Control That Cannot Be Fully Implemented

Example:

Required Control: MFA for a legacy application

Problem: The legacy application does not support MFA.

Instead of leaving the risk untreated, create an alternative control.

Step 7: Create the Compensating Control

Go to:

Control Catalog → Add Control

Enter:

Field	Example
Control Name	Compensating Control – Legacy Application Access
Description	Restrict legacy application access through VPN and IP allowlisting
Type	Detective/Preventive
Owner	IT Security Team
Status	Implemented

Save the control.

Step 8: Document the Attestation

In the control/risk documentation, record:

Reason for compensation:

The legacy application does not support MFA.

Compensating control:

Access is restricted through VPN, IP allowlisting and administrator approval.

Risk addressed:

Unauthorized access to the legacy application.

Control owner:

IT Security Team.

Attestation:

The compensating control provides an alternative security measure to reduce the risk associated with the absence of MFA.

Step 9: Attach Evidence

Add supporting evidence such as:

- VPN configuration

- IP allowlist
- Access approval record
- Security policy
- Review/audit record

Step 10: Review and Save

1. Review the control details.
2. Confirm the control owner.
3. Confirm the implementation status.
4. Confirm the compensating-control justification.
5. Attach evidence.
6. Save the record.

Output:

The screenshot displays the Eramba Internal Controls interface. On the left is a sidebar with navigation options: Dashboard, Program, Organization, Asset Management, Control Catalog, Internal Controls (selected), Policies, Policy Exceptions, Continuity Plans, and Support Contracts. A notification at the bottom of the sidebar states: "You are running Eramba Community. Upgrade to Enterprise and reach the stars. Check it out".

The main content area is titled "Internal Controls" and includes tabs for "Views" and "+". The "Add Item" form is open, showing the "General" tab. The form fields are as follows:

- Name ***: Multi-Factor Authentication
- Description**: Require MFA for user access to critical systems
- GRC Contact ***: Admin Admin (with a "+ Add" button)
- Control Operator Contact ***: Admin Admin (with a "+ Add" button)
- Related Policies**: (with a "+ Add" button)

At the bottom of the form are "Cancel" and "Save" buttons. The footer of the interface reads "© Help and Resources Eramba Community v. 3.30.1".

Multi-Factor Authentication

Internal Controls

General

Audits

Maintenances

Audit Dates *

No audits required

Audits required

Audit Execution

Manual

Automated

ⓘ Automated audits are only available for Enterprise customers.

Audit

Occurrence type

Specific

Periodical

Audit dates *

16-09

Add new +

The following audit will be created

16. Sep 2026

16. Sep 2027

Result:

The required security control and its implementation were successfully documented in Eramba, and a compensating control with justification, ownership, and supporting evidence was recorded for the case where the primary control could not be implemented.